Universidade Federal do Pará (UFPA)
Dr. Prof. Sandro Bezerra
Laboratório de Engenharia de Software
Aluno Luis Felipe Fernandes Cardoso

Relatório de Testes de Segurança

1. Reconhecimento Passivo

Descrição: Coleta de informações sem interagir diretamente com o alvo.

kali@kali - [~] $ whois acadmap.me

Informações coletadas:

- Domain Name: acadmap.me
- Registrar: NameCheap, Inc.
- WHOIS Server whois.namecheap.com
- Creation Date: 22/07/2025
- Expiry Date: 22/07/2026
- Status: ClientTransferProhibited
- Contact: Dados do registrante protegidos (privacy service by "Withheld for Privacy ehf")

Interpretação: Domínio criado recentemente, o que indica que a aplicação ainda pode estar em desenvolvimento; domínio protegido por serviço de privacidade, ou seja, não dá para descobrir o dono diretamente pelo Whois; o registrar é o NameCheap (comum para projetos menores e testes); status definido como "ClientTransferProhibited" impede que o domínio seja transferido para outra empresa de registro até que o dono remova o bloqueio (boa medida de segurança).

2. Reconhecimento Ativo

Descrição: Coleta de informações interagindo diretamente com o alvo.

2.1 Varredura de portas e/ou serviços abertos.

kali@kali - [~] $ nmap –sS –Pn –p- acadmap.me
Executa um SYN scan (rápido e comum) ignorando os testes de ping, varrendo todas as portas

kali@kali - [~] $ nmap –sV –sC –p [80,443(portas encontradas abertas)] acadmap.me
exibe mais detalhes sobre os serviços/portas encontrados abertos

Informações coletadas:

Após a execução do comando acima, foi detectado a porta 80 e 443 abertas no host acadmap.me (IP 168.75.88.175), rodando na versão nginx 1.24.0 / Ubuntu. Não há outros serviços expostos na rede como banco de dados, SSH, FTP etc. A versão do Nginx é relativamente nova, o que diminui a lista de vulnerabilidades graves conhecidas.Servidor redireciona HTTP para HTTPS. Nenhuma configuração crítica de TLS exposta.

2.2 Varredura de diretórios / arquivos escondidos

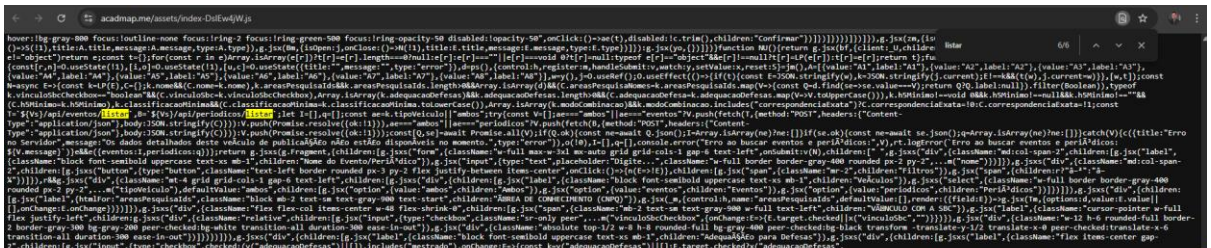
kali@kali - [~] $ dirb https://acadmap.me /usr/share/wordlists/dirb/common.txt -w -o dirb_result.txt -N 403

Diretórios encontrados:

- https://acadmap.me/api
- htpps://acadmap.me/assets

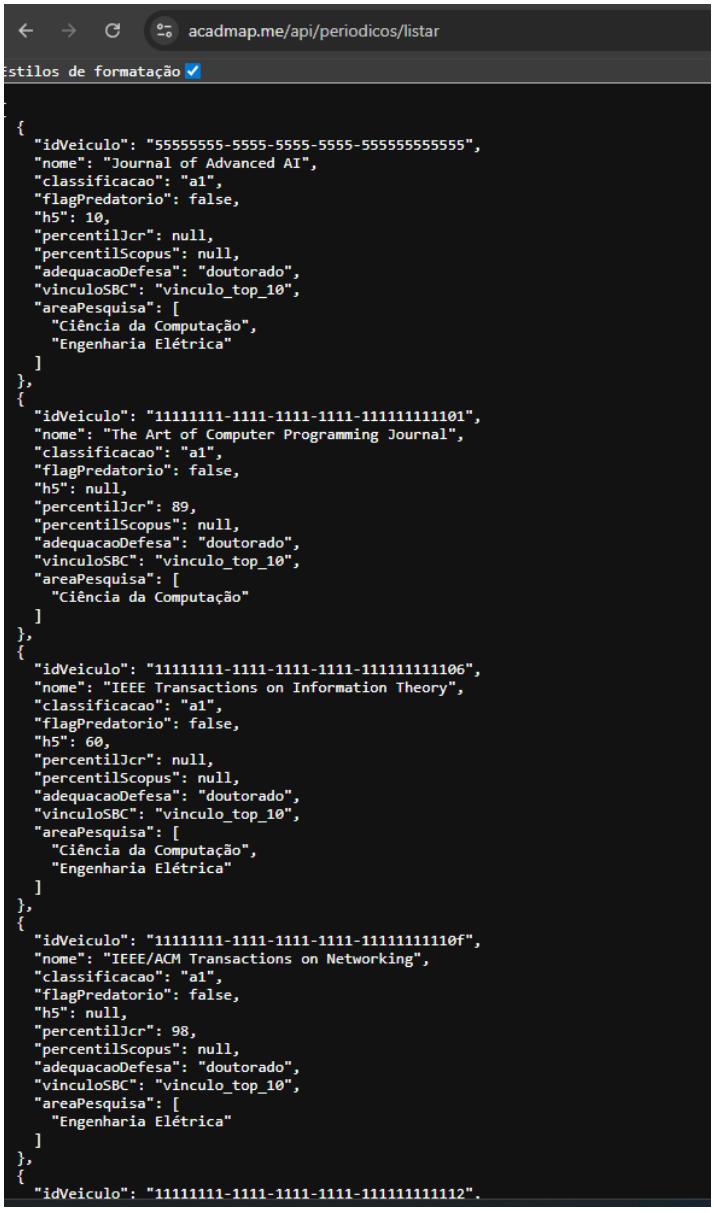
Acessando o arquivo .js a partir do código fonte da página foi possível encontrar alguns arquivos escondidos:





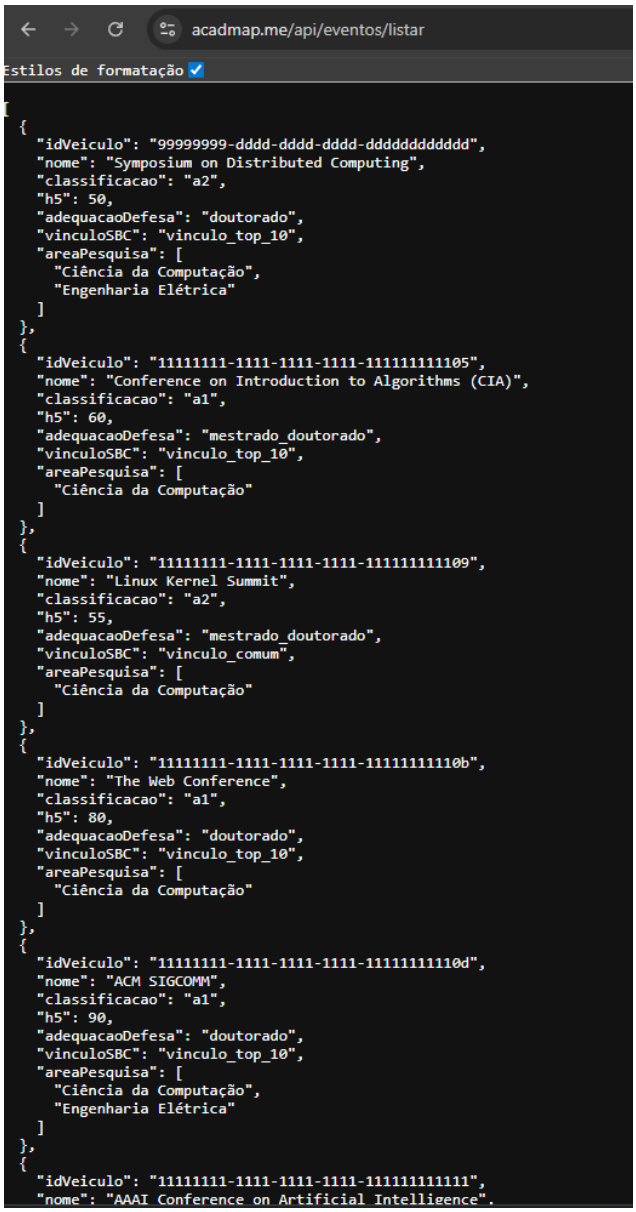
Diretórios/arquivos encontrados:

acadmap.me/api/periodicos/listar




```
[
  {
    "idVeiculo": "55555555-5555-5555-5555-555555555555",
    "nome": "Journal of Advanced AI",
    "classificacao": "a1",
    "flagPredatorio": false,
    "h5": 10,
    "percentilJcr": null,
    "percentilScopus": null,
    "adequacaoDefesa": "doutorado",
    "vinculoSBC": "vinculo_top_10",
    "areaPesquisa": [
      "Ciência da Computação",
      "Engenharia Elétrica"
    ]
  },
  {
    "idVeiculo": "11111111-1111-1111-1111-111111111101",
    "nome": "The Art of Computer Programming Journal",
    "classificacao": "a1",
    "flagPredatorio": false,
    "h5": null,
    "percentilJcr": 89,
    "percentilScopus": null,
    "adequacaoDefesa": "doutorado",
    "vinculoSBC": "vinculo_top_10",
    "areaPesquisa": [
      "Ciência da Computação"
    ]
  },
  {
    "idVeiculo": "11111111-1111-1111-1111-111111111106",
    "nome": "IEEE Transactions on Information Theory",
    "classificacao": "a1",
    "flagPredatorio": false,
    "h5": 60,
    "percentilJcr": null,
    "percentilScopus": null,
    "adequacaoDefesa": "doutorado",
    "vinculoSBC": "vinculo_top_10",
    "areaPesquisa": [
      "Ciência da Computação",
      "Engenharia Elétrica"
    ]
  },
  {
    "idVeiculo": "11111111-1111-1111-1111-11111111110f",
    "nome": "IEEE/ACM Transactions on Networking",
    "classificacao": "a1",
    "flagPredatorio": false,
    "h5": null,
    "percentilJcr": 98,
    "percentilScopus": null,
    "adequacaoDefesa": "doutorado",
    "vinculoSBC": "vinculo_top_10",
    "areaPesquisa": [
      "Engenharia Elétrica"
    ]
  },
  {
    "idVeiculo": "11111111-1111-1111-1111-111111111112",
```

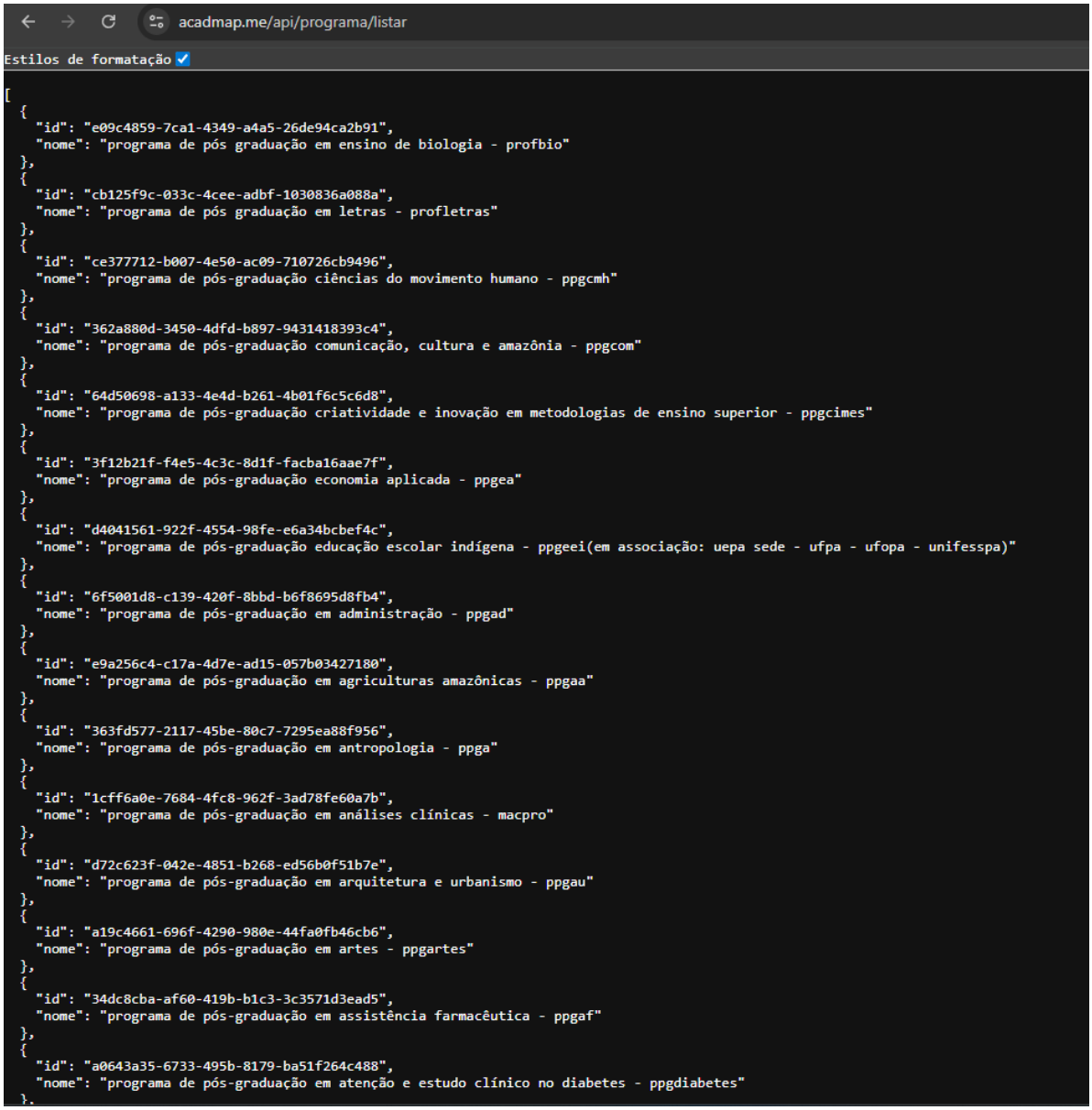
acadmap.me/api/eventos/listar



acadmap.me/api/areas/listar



acadmap.me/api/programa/listar



Diretórios sensíveis encontrados no arquivo index-DsIEw4jW.js não acessíveis via parâmetro URL:

- /api/log-erro/adicionar
- /api/log/adicionar
- /api/auth/refresh
- /api/usuario/cadastro
- /api/veiculo/periodico-pendente
- /api/veiculo/negar-veiculo/
- /api/veiculo/aprovar-veiculo/
- /api/log/historico
- /api/log-erro/historico
- /api/log-veiculo/historico

3. SSL/TLS & Headers

Descrição: Testar configuração do HTTPs e segurança do servidor

nmap –p 443 –script ssl-enum-ciphers acadmap.me

```
┌──(kali㉿kali)-[~/lab/acadmap.me/assets]
└─$ nmap -p 443 --script ssl-enum-ciphers acadmap.me

Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-03 15:24 EDT
Nmap scan report for acadmap.me (168.75.88.175)
Host is up (0.0070s latency).

PORT    STATE SERVICE
443/tcp open  https
| ssl-enum-ciphers:
|   TLSv1.2:
|     ciphers:
|       TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256 (secp256r1) - A
|       TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 (secp256r1) - A
|       TLS_ECDHE_ECDSA_WITH_CHACHA20_POLY1305_SHA256 (secp256r1) - A
|     compressors:
|       NULL
|     cipher preference: client
|   TLSv1.3:
|     ciphers:
|       TLS_AKE_WITH_AES_128_GCM_SHA256 (ecdh_x25519) - A
|       TLS_AKE_WITH_AES_256_GCM_SHA384 (ecdh_x25519) - A
|       TLS_AKE_WITH_CHACHA20_POLY1305_SHA256 (ecdh_x25519) - A
|     cipher preference: client
|_  least strength: A

Nmap done: 1 IP address (1 host up) scanned in 2.50 seconds
```

Interpretação do resultado:

Servidor está bem configurado em TLS, sem ciphers fracos ou RC4/3DES. TLS 1.3 habilitado (moderno e seguro). Não há compressão (Compressão: NULL, ou seja, evita ataques tipo CRIME).

Resumo: Robusto contra ataques de cypher downgrade e maioria das vulnerabilidades conhecidas de SSL/TLS

Definição ataques tipo CRIME (Compression Ratio Info-leak Made Easy): explora compressão de dados em protoclos HTTPS ou TLS/SSL, reduzindo o tamanho dos dados transmitidos e o tamanho resultante vaza informações sobre o conteúdo secreto, como cookies de sessão.

Definição ataques Cypher Downgrade: força a comunicação HTTPS a usar uma versão mais fraca ou vulnerável de criptografia.

4.0 SQL Injection

Descrição: Injeção de código SQL malicioso na interface de login da aplicação.

sqlmap -u "https://acadmap.me/login" --data="username=admin&password=123" --risk=2 --level=2 --batch

Saída:



Interpretação: parâmetros não parecem ser injetáveis, o que indica uma boa segurança no sistema de login, ao menos contra injeções padrões.